

Abstract

ISO/IEC 27037:2012 is an international standard that provides guidelines for the identification, collection, acquisition, and preservation of digital evidence, with a particular focus on the roles of Digital Evidence First Responders (DEFR) and Digital Evidence Specialists (DES). The standard was developed by ISO and IEC to ensure that evidence remains intact by following strict procedures.

ISO/IEC 27037 complements other standards such as ISO/IEC 27001 (Information Security Incident Management) and ISO/IEC 27035 (Security Incident Management).

Key steps include identification, where the first responder detects potential evidence at the crime scene; collection, where digital media is safely transferred; acquisition, which involves creating exact copies without altering the data; and preservation, where data is stored in secure environments to prevent tampering or destruction.

Special attention is given to volatile data, as it may be lost once a device is powered off. First responders must follow best documentation practices, maintain the chain of custody, and ensure that the handling of evidence is reliable and legally admissible.

ISO/IEC 27037 does not replace national laws but facilitates cooperation across different jurisdictions. Forensic readiness is a crucial factor that enables organizations to respond promptly to incidents. Additionally, compliance with guidelines such as those set by INTERPOL, which describe practices for digital evidence seizure and analysis, is emphasized.

The standard covers four fundamental principles in evidence management: auditability, justifiability, repeatability, and reproducibility, ensuring that the same method can be applied again with consistent results.

Investigations follow specific stages, from general inquiry to detailed data analysis on computers and mobile devices, highlighting critical actions such as immediate network disconnection and log file and system examination. In cases of encrypted data, specialized recovery techniques are employed.

Finally, documentation and report drafting are essential for the legal acceptance of evidence, while changes in Criminal Procedure (*Article No. 265 of the Greek Code of Criminal Procedure*) underscore the importance of specialized reports on digital data seizures.

Keywords: ISO/IEC 27037:2012, ISO/IEC 27001, ISO/IEC 27035, INTERPOL, Digital Forensics, Digital Evidence First Responders - DEFR, Digital Evidence Specialists - DES, Chain of Custody, Cybersecurity, Forensic Readiness, Volatile Data, Cryptography, GDPR.

In this article

INTRODUCTION.....	3
1 BACKGROUND AND PURPOSE OF ISO/IEC 27037:2012	5
1.1 RELATIONSHIP WITH OTHER STANDARDS	6
1.2 FORENSIC READINESS	6
1.3 PROCESS FOR COLLECTING AND HANDLING DIGITAL EVIDENCE	6
1.4 CHALLENGES AND COMMON MISTAKES IN DIGITAL EVIDENCE COLLECTION	7
1.5 DIGITAL FORENSICS.....	7
2 ROLE OF FIRST RESPONDERS (EAER).....	8
2.1 RESPONSIBILITIES AND DUTIES	8
2.2 CHALLENGES AND COMMON MISTAKES.....	8
2.3 MANAGING VOLATILE DATA	9
2.4 VOLATILE DATA USE CASES.....	9
2.5 EXAMPLES OF VOLATILE DATA	10
2.6 THE ORDER OF DATA VARIABILITY	11
2.6.1 Registers and cache.	12
2.6.2 Ram.	12
2.6.3 Temporary file systems.	12
2.6.4 Disk storage.	12
2.6.5 Archival means.	12
3 TECHNIQUES AND PROCEDURES OF ISO/IEC 27037:2012	14
3.1 ACTIONS DURING RECOGNITION.....	14
3.1.2 Documentation.....	14
3.1.3 Collection.....	14
3.2 SURVEILLANCE CHAIN.....	15
3.2.1 Acquisition.....	15
3.2.2 Conservation	16
4 RELATIONSHIP WITH LEGAL AND INTERNATIONAL REQUIREMENTS.....	17
5 CASE STUDIES.....	18
6 FIRST RESPONDERS' ACTIONS DURING THE INVESTIGATION.....	19
6.1 INVESTIGATION OF COMPUTERS IN OPERATION.....	19
6.2 SPECIAL INVESTIGATION ON MOBILE PHONE IN OPERATION	20
6.3 ACTIONS REQUIRING ATTENTION - SPECIAL MENTION - RECORDING - SEIZURE ACCORDING TO ISO/IEC 27037/2012.....	20
6.3.1 Special Report on the Seizure of Digital Data	21
7 CONCLUSIONS AND FUTURE PROSPECTS	23
8 BIBLIOGRAPHY - SOURCES:	24
APPENDIX I - DIGITAL EVIDENCE DICTIONARY.....	25
DEFINITIONS	25

Introduction

ISO/IEC 27037:2012 is an essential standard that guides experts in identifying, collecting, obtaining, and preserving digital evidence, ensuring their credibility in legal proceedings. It is primarily aimed at first responders (DEFRs) and digital forensics experts (DES), who manage data with the aim of maintaining its integrity.

The standard was issued in 2012 by ISO and IEC, under the supervision of the ISO/IEC JTC1/SC 27 Technical Committee, and was confirmed in 2018 as up-to-date. It is linked to other standards, such as ISO/IEC 27001 for information security management and ISO/IEC 27035 for security incident management.

Digital evidence management involves four main stages:

- Identification: Identifying and documenting potential evidence, with attention to the nature and volatility of the data.
- Collection: Implement secure methods of removing data from the incident site.
- Acquisition: Creating accurate copies, maintaining their authenticity and integrity.
- Preservation: Secure storage to prevent modification or destruction.

Maintaining the chain of custody is critical, as it ensures that every change or transfer of data is recorded in detail. First responders play a crucial role, especially in managing volatile data that can be lost if the device is turned off.

The standard does not replace national legislation, but is a useful guide to facilitate the exchange of data between jurisdictions. It emphasizes forensic readiness, i.e. the ability of organizations to effectively manage security incidents. At the same time, it proposes compliance with international guidelines, such as those of INTERPOL.

The basic principles of the standard include:

- Auditability: Ability to independently control each action.
- Justifiability: Documentation of each decision and method.
- Repeatability: Ability to apply the same method with the same results.
- Reproducibility: Preservation of results under different conditions.

The application of ISO/IEC 27037 involves the proper investigation and analysis of data on computers and mobile devices. First responders must disconnect devices from the network to prevent remote management, check logs, and maintain the original state of the data. In cases of encryption, specialized recovery techniques are employed.

Particular attention is paid to the preparation of reports to ensure that the evidence is accepted in the legal framework. In Greece, the collection and retention of digital evidence complies with the Code of Criminal Procedure (Article 265 of the Code of Criminal Procedure), which requires a special seizure report, ensuring the integrity, reproducibility and authenticity of the data.

Sealing evidence prevents evidence from being tampered with, and the standard is also applied to cloud computing environments, allowing data to be extracted and securely stored by online services.

In conclusion, ISO/IEC 27037:2012 stands as a fundamental guide for digital evidence management, ensuring compliance with legal requirements and maintaining data integrity. Continuous technological evolution necessitates revisions and stricter standards, while the training and preparation of professionals remain critical for its effective implementation.

1 Background and purpose of ISO/IEC 27037:2012

ISO/IEC 27037:2012 is an international standard that provides guidance for the identification, collection, acquisition and retention of digital evidence in the context of information security incident management. It was issued in 2012 by the International Organization for Standardization (ISO) and the International Electrotechnical Commission (IEC), as part of the ISO/IEC 27000 series of standards. focused on information security management.

The standard aims to provide best practices and procedures that ensure the integrity of evidence collected in cases of cybercrime or other information security-related incidents.

The 2012 edition was the first official form of the standard, which came to fill a gap in the management of digital evidence, as until then there was no commonly accepted framework for these procedures.

In 2018, the standard was revised, but no new version was issued - instead, its principles were incorporated into other relevant standards, such as ISO/IEC 27042 (Guidelines for the Analysis of Digital Evidence) and ISO/IEC 27043 (Guidelines for the Management of Information Security Incidents).

ISO/IEC 27037:2012 is closely related to other standards in the ISO/IEC 27000 family, mainly ISO/IEC 27001 and ISO/IEC 27002. ISO/IEC 27001 is the basic standard for Information Security Management Systems (ISMS), specifying the requirements for the implementation and certification of such a system. ISO/IEC 27002, on the other hand, is a best practice guide for information security measures.

ISO/IEC 27037 complements these standards, focusing specifically on digital evidence management and supporting digital forensic investigations. Proper evidence management is critical for compliance with ISO/IEC 27001, especially when an organization is dealing with security incidents and needs to demonstrate the integrity of its investigations.

The scope of ISO/IEC 27037:2012 encompasses the basic principles and procedures that must be followed to maintain the validity of digital evidence.

The standard is primarily aimed at cybersecurity professionals, digital forensics analysts, legal advisors, as well as organizations that manage critical information. Sets out best practices for extracting and preserving evidence from electronic devices, computational systems, networks, and storage media, ensuring that such information is admissible in legal proceedings or internal security investigations.

Additionally, the standard provides guidelines for the use of technologies such as encryption, digital signatures, and metadata logging techniques, aiming to minimize the risks of evidence tampering or destruction.

Overall, ISO/IEC 27037:2012 stands as an important tool for managing security incidents, ensuring the integrity of digital evidence and organizations' compliance with international best practices.

ISO/IEC 27037 complements other international information security standards, such as ISO/IEC 27001 (Information Security Management) and ISO/IEC 27002 (Practice Guide for the Implementation of Information Security Controls). In addition, it is directly related to ISO/IEC 27035, which concerns the management of information security incidents. While it is not a legal text, it can support compliance with national laws and regulations, facilitating the exchange of digital evidence between jurisdictions.

Forensic readiness refers to an organization's ability to detect, collect, acquire, maintain and analyse digital evidence. ISO/IEC 27037 does not cover forensic readiness, but

recognises its importance in supporting digital evidence handling processes. Organizations with a high level of forensic preparedness can respond faster and more effectively to security incidents.

The standard specifies four key phases in digital evidence management:

It involves identifying devices or data that may contain evidence. An important element is the protection of the crime scene to avoid alterations.

Evidence must be collected by methods that ensure its integrity. It includes the labeling and documentation of data, as well as maintaining the chain of custody.

iii. Acquisition

Acquisition involves making a legal copy of the data, either through physical or logical acquisition. The procedure must be documented in detail.

iv. Preservation

The data is stored in a secure environment to preserve its integrity and allow for subsequent analysis.

1.4 Challenges and Common Mistakes in Digital Evidence Collection

The most common challenges and mistakes include:

- Insufficient documentation of procedures.
- Improper maintenance of the chain of custody.
- Improper management of volatile data.
- Interference with active systems that may result in data loss or modification.

1.5 Digital Forensics

Digital Forensics is a critical field of cybersecurity, which deals with the systematic analysis, collection, and preservation of digital evidence. At its core is the definition and key concepts related to the investigation and management of evidence of a digital nature, as referred to in the ISO standard/IEC 27037:2012.

The process begins with identification, in which the potential carriers of digital data (such as computers, hard drives, USBs, mobile phones) are identified in the context of an incident or crime.

This is followed by collection, in which the data is removed from its original location and stored in a secure environment for further analysis. Upon acquisition, faithful copies of the data are created using appropriate methods, while preservation aims to ensure the integrity and authenticity of the items through proper storage and documentation.

These actions are governed by the principles of repeatability, documentation, justification and independent assessment to ensure the reliability of the data. It is widely applied in security incident management, where data analysis can provide critical insights to determine the cause of an incident, mitigate damage, and enhance mechanisms to prevent future attacks.

Additionally, compliance with national laws and facilitating the exchange of evidence across jurisdictions underscore the international significance and complexity of Digital Forensics, making it essential for cyber protection and support legal and judicial processes.

2 Role of first responders (EAER)

2.1 Responsibilities and duties

The role of Digital Evidence First Responders (DEFr) is fundamental to the management and safeguarding of digital evidence, as defined by the ISO/IEC 27037:2012 standard. DEFrs are considered to be the first to be informed and react to a security incident. In particular, their role includes identifying, collecting, acquiring and retaining digital data, in particular volatile data, that are critical for forensic analysis.



This process requires rigorous documentation of all actions, with a view to ensuring the integrity and authenticity of the evidence. DEFrs must understand the nature of the incident, gather as much information as possible, and share their findings with experts so that appropriate decisions can be made. Their responsibilities include proper documentation and avoiding common mistakes, such as not maintaining the chain of custody or using unapproved data collection methods. Challenges include the complexity of technologies, the need to comply with legal and regulatory requirements, and the prevention of data alteration during

processing. However, it is understood that first responders (DEFrs) play a crucial role in the management of digital evidence, ensuring the accuracy and integrity of data from identification to retention. Every decision made in the identification and collection process has a direct consequence on the quality of forensic analysis, making compliance with ISO/IEC 27037:2012 crucial for the success of the investigation.

2.2 Challenges and Common Mistakes

Indicatively, errors that can occur include not disconnecting devices from networks in a timely manner, not using proper methodology to manage volatile™ data, and lack of knowledge about specific applications or systems that may contain evidence.

The main mistakes of the first responders are undoubtedly the following:

- ✓ No documentation of the data collection process
- ✓ Turn off or restart suspicious computers or smart devices with operating system.

- ✓ The assumption that some parts of the suspicious machine may be reliable and easy to use - in use.
- ✓ Not to take into account the basic knowledge of suspicious systems - machines.

Thus, DEFRs must be well-trained, familiar with international standards, and possess the technical skills needed to handle even the most complex cases, ensuring that digital data collection and analysis are carried out professionally and accurately.

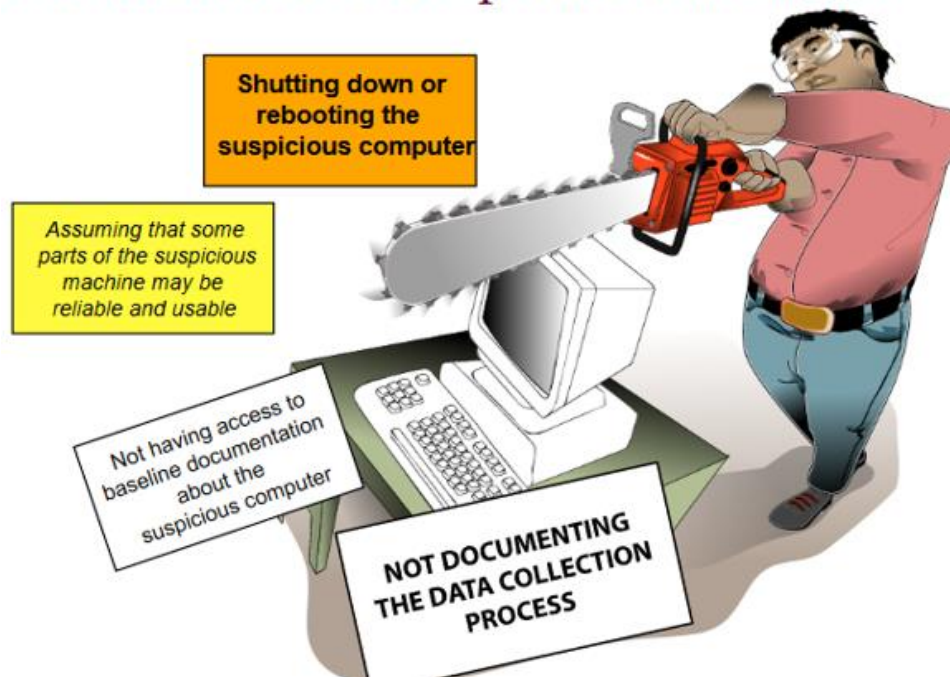
2.3 Managing Volatile Data

Volatile Data is information that is lost when a system shuts down. Therefore, the DEFR must use special tools to collect them while the system is in operation. This process requires careful planning and the use of appropriate methodologies.

This data is information that is temporarily stored in a computer's RAM while the system is running.

It is critical in computer forensics and cybersecurity, for real-time analysis and investigation. Unlike immutable data, volatile data is lost when the computer is turned off.

Common First Responder Mistakes



2.4 Volatile Data Use Cases

In digital forensics, researchers identify and need to collect and analyze volatile and unstable data. They gather data, identify active processes - processes and reveal recent user activity.

Cybersecurity analysts can examine RAM to identify processes that execute malicious code and unauthorized activities, such as:

- ⇒ Operating systems use volatile memory to store data that is currently in use by running applications. Memory management techniques help optimize system performance.
- ⇒ The operating system allocates time segments to each process to ensure fair distribution of the CPU. This allows processes to run without interference with each other.
- ⇒ CPU cache is a small but extremely fast memory that is used to store frequently accessed data and instructions. Cache management helps optimize data access and minimize cache loss, improving system performance.
- ⇒ Virtual memory expands the available address space beyond physical RAM. It allows processes to use more memory than is physically available by switching data between RAM and disk storage.
- ⇒ Volatile data is temporary and is lost when the system is turned off. However, some data can be stored for a short period of time if a system crashes or shuts down unexpectedly. Some operating systems use mechanisms such as "crash dumps" to capture specific unstable data before shutting down.
- ⇒ The system stores the contents of the volatile memory in non-volatile storage before being turned off or entering low-power modes. When the system reboots, it restores the stored data to the RAM so that users can pick up where they left off.

What is Volatile Data?

Definition: Any data stored in system memory that will be lost when the machine loses power or is shut down

Location: Registers, cache, and RAM (this module focuses on RAM)



2.5 Examples of Volatile Data

- ⇒ Information about active programs and system tasks (running processes).

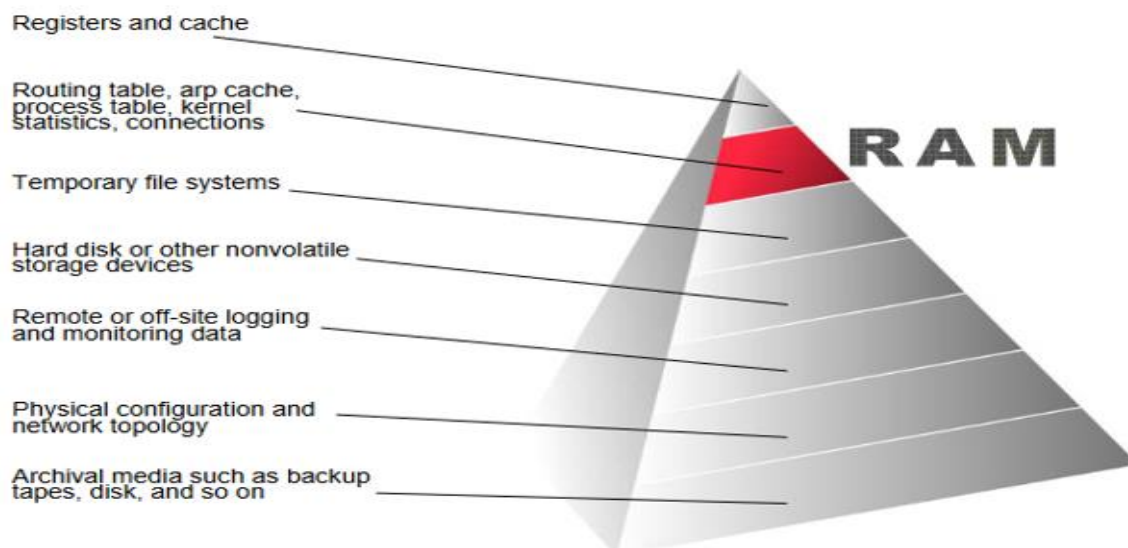
- ⇒ Details about current network connections.
- ⇒ Temporary variables used by the operating system.
- ⇒ Text or data that is temporarily stored on the clipboard.
- ⇒ Cached data stored in volatile memory for faster access (RAM cache).

2.6 The order of data variability

The Order of Volatility specifies that the items most likely to be destroyed must first be collected. The correct order of these sources of evidence in order of variability is RAM first, as the contents of RAM are erased when the system is turned off.

The meaning of the above term plays a crucial role in digital forensics and incident response, shaping the systematic approach to the collection of digital evidence. This

Order of Volatility



principle revolves around prioritizing the collection and preservation of unstable data—information found in a computer's memory or caching—based on its susceptibility to rapid change or loss.

This methodology is critical for maintaining the integrity and admissibility of digital evidence in legal proceedings, emphasizing a methodical process of collecting from the most volatile to the least stable data sources. In digital forensics, the variability order categorizes data based on its volatility, moving from the most ephemeral to relatively stable forms.

These categories include registrars and RAM caches, temporary file systems, disk storage, and archiving media. Each layer has different types of data that are crucial for surveys. For example, RAM contains active network connections, running processes, open ports, and

saved credentials. Understanding these categories empowers forensic researchers to plan their data collection methods effectively.

RFC 3227, titled "*Guidelines for Evidence Collection and Archiving*," provides essential guidance for digital forensics and incident response professionals. It outlines best practices for collecting and preserving digital evidence, emphasizing documentation of the entire process, from collection to analysis and chain of custody preservation. Adhering to these guidelines ensures a standardized and responsible approach to preserving digital assets.

2.6.1 Registers and cache.

This category includes data stored in processor registers and CPU cache — the fastest and most unstable types of memory, containing temporary data used by the processor during operations.

2.6.2 Ram.

RAM keeps the app's operating system and data in current use. Very volatile, its contents are lost when the system shuts down. Forensic tools like FTK Imager and EnCase can capture RAM snapshots for analysis.

2.6.3 Temporary file systems.

These include temporary file systems like /tmp and /run on Linux. Such file systems often contain temporary files that are created during the operation of the system. It can also include temporary data stored in the %TEMP% folder in Windows, as it often stores short-lived data, but it is rare for Windows to mount actual temporary file systems. In Windows IR, attached optical media (CD/BluRay) or attached ISO files could be considered a temporary file system if you do not have access to the source media.

2.6.4 Disk storage.

Disk storage includes hard drives, SSDs, and other permanent storage devices. Although less volatile than RAM, disk storage can be modified if the system continues to function after an incident. Collection can be carried out with tools such as dd (on Linux) or applications such as FTK Imager, dcfldd, dc3dd, ewfacquire, etc.

2.6.5 Archival means.

This category includes long-term storage, such as backups and logs. These are the least volatile and are kept for historical reference.

Meticulous collection of volatile data is paramount in the context of cyber hacks. Volatile data, located in a computer's memory or cache, contains critical evidence for ongoing cyber incidents. Active network connections can reveal suspicious communications, running

processes indicate active applications (some potentially malicious), and open ports and stored credentials offer insights into potential vulnerabilities and unauthorized access, helping researchers understand the attacker's intrusion tactics and points.

Timely collection of volatile data is essential for understanding the current state of the intrusion and completely reconstructing the digital crime scene. It allows incident responders to uncover the attacker's tactics, techniques, and procedures (TTPs), helping to build a strong case for legal proceedings.

By demonstrating a comprehensive understanding of the timing of the intrusion, the tools used, and the impact on the victim's system, incident responders can provide accurate, reliable, and acceptable evidence.

Prioritizing volatile data collection ensures that digital investigators have the necessary context and evidence to respond effectively to cyber incidents, contributing significantly to the pursuit of justice in addressing cybercrime.

3 Techniques and procedures of ISO/IEC 27037:2012

ISO/IEC 27037:2012 is an international standard that offers guidelines for identifying, collecting, obtaining and retaining digital evidence. The procedures outlined in the standard are crucial to ensure the integrity and probative value of the data, which is used in forensic investigations.

It provides a clear and comprehensive framework for managing digital evidence. Proper implementation of the identification, collection, acquisition and retention procedures ensures the reliability and legal acceptability of evidence.

Documentation and adherence to strict standards are essential to ensure integrity at every stage of the process.

Rigorous implementation of identification, collection, acquisition, and retention procedures ensures the reliability and legal acceptability of evidence, contributing substantially to the successful conduct of digital forensic investigations.

Identification is the first step in the process of handling digital evidence. It involves researching to identify and substantiate potential evidence related to a case.

3.1 Actions during recognition

3.1.1.1 Search at the scene of the incident. Devices such as computers, mobile phones, hard drives, and other storage media are detected.

3.1.1.2 Recording the situation. The devices are photographed in the place where they were found to avoid alteration of the layout.

3.1.1.3 Prioritization. Evidence is categorized based on its perishability and significance. For example, volatile data (e.g., RAM) is handled first.

3.1.2 Documentation

Documentation is a crucial stage in the evidence management and retention process, as it ensures the integrity, authenticity, and repeatability of data. At this stage, all information about the item in question is recorded in detail, including its physical location, its connection to other objects, and its operating status. Accurate and detailed recording of the actions that take place during the recognition process allows the results to be faithfully reproduced and errors or misinterpretations avoided.

3.1.3 Collection

The process of collecting evidence is carried out with strict protocols to prevent any possibility of data corruption or loss. Important parameters that are considered when collecting include:

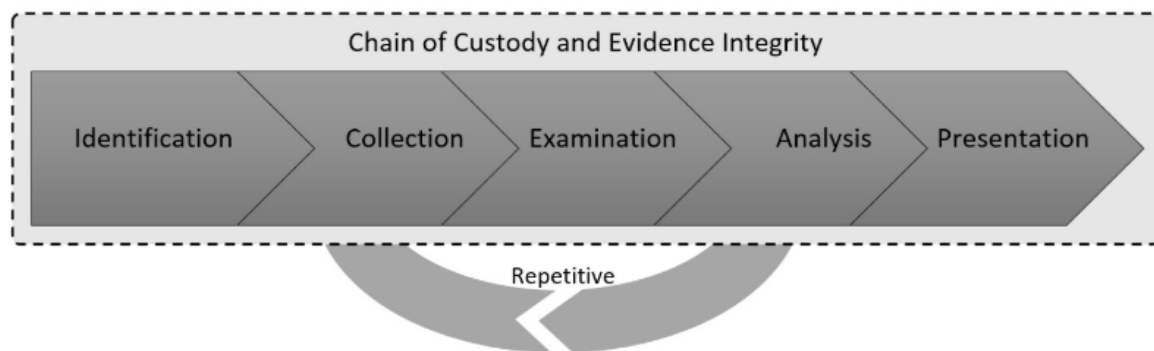
3.1.3.1 Safety. *Devices and digital media are carefully disconnected from networks or other connections in order to prevent data loss or unauthorized modification. Especially in cases where there is a risk of automatic deletion of files, additional data retention methods are applied.*

3.1.3.2 Packaging. *Items are placed in appropriately sealed and secure storage areas to protect them from external factors that could affect their integrity.*

3.1.3.3 Marking. *Each item bears a unique identification label, which records basic information such as the type of object, the date of collection, and its manager. This information is recorded in detail in the documentation file to ensure the traceability of the evidence.*

3.2 Surveillance Chain

To maintain the validity of evidence, the Chain of Custody is a vital process. Any transfer or processing of data is recorded in detail, with reference to the person responsible who performed the action, the date and the conditions of the transfer. This continuous monitoring ensures that there is no loss or alteration of the items during their examination.



3.2.1 Acquisition

The acquisition process involves making copies of the digital data using secure methods to prevent any modification of the original data. The choice of the appropriate acquisition method depends on the type of data and the environment in which it is located. The main methods include:

⇒ Physical acquisition.

It involves extracting data from storage media, such as hard drives, USB drives, or memory cards. This process requires specialized tools and techniques to maintain data integrity.

⇒ Reasonable acquisition.

It involves copying specific data or files from functional devices, without the need to physically remove the storage medium.

⇒ Special cases.

It involves addressing challenges such as recovering encrypted data, managing extremely large files, or dealing with non-standard forms of data storage.

During the acquisition process, the methods, tools, and settings used are recorded in detail to ensure the repeatability of the process. The integrity of the copies is verified through processes such as comparing hash values between the original and the copy.

3.2.2 Conservation

The preservation process focuses on the safe storage of evidence in order to prevent any loss or alteration. This is achieved through the following actions:

Evidence is stored in environments with strictly restricted access. Storage areas have security systems in place, such as controlled access, entry-exit recording, and camera monitoring.

To prevent physical damage, sealed packaging is used, as well as temperature and humidity control systems.

Regular checks are carried out to confirm the integrity of the data. The use of techniques such as digital signature and hashing allows for the detection of any unauthorized modifications.

3.2.2.1 Documentation of conservation

In order to ensure the transparency and validity of the retention process, the following information shall be recorded:

- ⇒ Storage conditions, including technical protection measures.
- ⇒ The integrity checks carried out and their results.
- ⇒ Any action that took place during the storage period, such as movements, inspections or maintenance of the stored items.

The overall documentation of these processes ensures that the evidence remains reliable and unaltered, allowing for its safe use in legal and technical analyses. By adhering to strict procedures and standards, data integrity is maintained throughout its lifecycle.

4 Relationship with legal and international requirements

Compliance with national laws and international regulations is crucial for the legal and secure management of digital evidence. ISO/IEC 27037 provides guidelines that ensure data integrity, reproducibility, and authenticity, facilitating collaboration across jurisdictions.

The standard includes four main processes: identification, collection, acquisition and retention of digital assets. Authentication involves identifying critical data from devices or networks, while in cloud environments the process is complicated due to the distributed nature of data and the involvement of multiple providers. The collection of digital evidence must ensure its integrity, preventing alteration or loss.

Data acquisition involves creating exact copies, often using encryption and virtualization technologies, especially in cloud environments. Preserving items requires secure storage spaces and techniques, such as timestamping and digital signatures, that ensure their authenticity.

Maintaining the chain of custody is critical, especially in multidimensional networks, where the analysis of log files and network communications plays an important role. In corporate or public networks, data collection requires rigorous documentation and compliance with standards, such as ISO/IEC 27001 and 27002, which ensure the confidentiality and integrity of information.

Forensic readiness is crucial, enabling organizations to respond effectively to security incidents. In cloud environments, the application of Article 265 of the Code of Criminal Procedure establishes the procedure for seizing digital data, ensuring its legality and reliability.

In conclusion, compliance with international standards and legal requirements is a key pillar for digital evidence management. ISO/IEC 27037 offers a comprehensive framework that promotes transparency, security, and international cooperation, ensuring that evidence remains reliable and acceptable in legal proceedings.

5 Case Studies

Case studies are a crucial tool in understanding and applying ISO/IEC 27037, which focuses on the proper management of digital evidence, encompassing the phases of identification, collection, acquisition, and retention.

A hypothetical implementation scenario could involve a cyberattack on a financial institution, where an immediate response is required to identify the sources of the breach and safeguard the evidence.

In this context, the incident management team applies the principles of forensic readiness, as described in the standard, ensuring that the crime scene is protected from possible tampering with data.

Prioritizing the collection of volatile data, such as RAM and live connections, is considered critical because this data can be lost if not addressed promptly. The success of this scenario depends on the observance of chain of custody rules, which ensures the integrity of the data and the reproducibility of the findings.

However, challenges are identified, such as a lack of specialized tools or the absence of adequate training of first responders, which can lead to failures.

An example of a factual case is the investigation of a data breach in a retail business, where the mishandling of evidence during its acquisition led to its rejection in court.

The analysis of this incident highlights the importance of complying with ISO/IEC 27037:2012 guidelines and the need to enhance staff training.

Another case concerns the successful investigation of fraud on an online platform, where the implementation of the standard led to the rapid and documented collection of evidence, allowing authorities to identify the perpetrators. Successes of this nature underscore the importance of standardizing procedures and leveraging international standards, such as ISO/IEC 27037:2012, to enhance confidence in the forensic outcome and process efficiency.

Case studies highlight both successes and failures, making it clear that adherence to guidelines and enhanced forensic preparedness can be crucial factors in successfully addressing modern cybersecurity challenges.

6 First responders' actions during the investigation

ISO/IEC 27037 refers only to evidence that is already in digital form and obviously not to similar objects whose possession may be criminal or constitute evidence for the case under investigation.

It should be noted that the standard does not deal with the conversion of analogue data into digital form (e.g. digitization of images appearing, representations of child pornography, etc.).

6.1 Investigation of Computers in Operation

In case of a blocked account, we request the entry of the defendant in it or the indication of the code, for our entry into the operating environment, by performing the following actions:

- ⇒ Control on the desktop of the PC and the applications that are running at that time.
- ⇒ Immediate disconnection of the device from the network, as there is a risk of remote management.
- ⇒ Check recent-quick access or in the path
C:\Users\"username"\AppData\Roaming\Microsoft Windows\Recent.
- ⇒ Enable the view of hidden files and folders.
- ⇒ Control of the users who manage the specific computer (cmd: net users).
- ⇒ Control of devices that are on the local network. (e.g. maintaining a local file server).
- ⇒ Check for the installation date of the operating system (cmd: systeminfo, focusing on OriginalDate).
- ⇒ Special investigation on a computer in operation.
- ⇒ Control of installed programs (control panel or explorer).
- ⇒ Check for installed virtual machines.
- ⇒ Check for encrypted files (containers) or entire partitions (hard disk drive) and corresponding programs to encrypt them. In case they are found, especially if they were found decrypted, it is absolutely necessary to export or create the Memory.dmp or minidump file for the subsequent possible decryption of the container by the forensic laboratories of the police authorities.
- ⇒ Check for the connection history of portable usb devices, in the system registry, by typing in the search regedit or with windows+R, in the path: H LOCAL MACHINE/SYSTEM/CURRENTCONTROLSET/ENUM/USBTO R.
- ⇒ Check the Appdata folder for programs, records that interest us.
- ⇒ Control in folders related to reception, e.g. in p2p programs. Shared folders, incoming.

- ⇒ General search with keywords that interest us. For example, in cases of child pornography, one of the words is PTHC.
- ⇒ More general search for file types by writing for example *.jpg, *.mp4, *.avi, *.flv.
- ⇒ Control, given that there is a decree that defines it in communication programs, browser history, email accounts, social media, cloud services, credentials in accounts by browsers, otherwise a superficial search is carried out on data related to external contact information, e.g. photos, installers.
- ⇒ Control of installed programs (control panel or explorer).
- ⇒ Check for installed virtual machines.
- ⇒ Check for encrypted files (containers) or entire partitions (hard disk drive) and corresponding programs to encrypt them. In case they are found, especially if they were found decrypted, the export or creation of the Memory.dmp or minidump file is absolutely required for the subsequent possible decryption of the container by the Forensic Service of the Law Enforcement Authorities.

6.2 Special investigation on mobile phone in operation

- ⇒ Turn on airplane mode.
- ⇒ App list overview and Photo/video gallery control.
- ⇒ Check the settings for linked accounts (google etc) on the device as well as the storage space (if it has a microSD buttoned)
- ⇒ Removing a device lock (or recording it in cases where it is not advisable to remove it, * Second Space)
- ⇒ Checking every application that is of interest to the case (e.g. facebook/gmail and their linked accounts and their content in case there is a privacy waiver)
- ⇒ Check the files stored on the device with the file manager (videos/photos plus other files and folders of interest)
- ⇒ If the illegal material is not detected, while there are strong indications that the phone is involved in the illegal activity, check for special hiding applications (eg Ar Lock, Hide it pro) or e.g. on Xiaomi devices with MIUI which are popular, Second Space (be careful when removing a lock on a Xiaomi device, the second space is deleted, as if there is no lock it is not functional).

6.3 Actions requiring attention - special mention - recording - seizure according to ISO/IEC 27037/2012

Investigating computers running Linux and macOS operating systems requires specialized methods, such as analyzing files, folders, and using the command line. In central units or

laptops, it may be necessary to remove the storage media, while in case of damage to the evidence, their condition must be described in detail in the seizure report.

During the investigation, no personal storage medium must be attached to the investigated unit. If this is unavoidable, prior consultation and recording of the action with an accurate timestamp is required. Particular attention is paid to cases of hidden servers or RAID systems (such as RAID 0), where the seizure of the entire computing unit is necessary to maintain the ability to recover the data from the forensic laboratories.

Documenting the findings includes recording the SIM card PIN number and screen lock code, if indicated by the suspect, with a recommendation to convert the unlock pattern into a numeric code instead of deactivating it. During seizure, any contact of the suspect with the evidence, as well as its activation, is prohibited.

In cases of unknown connection devices, devices or files, the head of the investigation is informed and, if necessary, the assistance of specialized personnel is requested. Additionally, accurately recording the start and end of the survey, as well as the time when the devices were turned off, is critical to the validity of the process. After turning off the devices, the relevant report is drawn up.

6.3.1 Special Report on the Seizure of Digital Data

With the amendment of the Code of Criminal Procedure (Law 4620/2019, article 265 of the Code of Criminal Procedure), it becomes mandatory to draw up a Special Report on the seizure of digital data. The time of writing the report is included in the main report of the research and the same evidence is recorded, accompanied by three critical elements: integrity, reproduction and authenticity.

The seized digital data are sealed in a special envelope in the presence of all competent persons (two investigating officers, a judicial officer and the person under investigation), with a relevant reference in the report. In cases of data held in cloud computing infrastructures, the process includes the extraction and storage of a copy, followed by the removal of the data from the account of the person involved, in accordance with the provisions of the law.

First responders must use RF shielding materials, such as Faraday bags or aluminum foil, to isolate cell phones and other wireless devices after they are seized. This shielding prevents the receipt of calls, messages or other signals that could modify the seized data.

7 Conclusions and future prospects

ISO/IEC 27037:2012 is a key standard in cybersecurity, focusing on the process of identifying, collecting, obtaining, and retaining digital evidence. It provides a clear management framework that ensures transparency, integrity, and repeatability, making it critical for forensic investigations and legal proceedings.

Despite its strengths, the standard faces challenges due to rapid technological advancements, such as cloud computing, big data, and IoT, which are not adequately covered. Its adaptation to new technologies and its revision are necessary to maintain its effectiveness.

The evidence management process is based on the identification, collection, acquisition, and preservation phases. Enhancing these processes can be achieved through advanced tools, staff training, and the adoption of best practices. The use of artificial intelligence to identify and categorize evidence, as well as real-time chain of custody management, can improve the reliability of evidence.

Complying with different countries' legal requirements is challenging. The creation of specialized guidelines and cooperation with international organizations, such as INTERPOL, could enhance the coherence of procedures. At the same time, the lack of forensic readiness in many organizations makes it necessary to develop integrated plans, including policies, procedures and training programs.

On a technological level, the integration of cryptography, blockchain, and tamper-detection mechanisms can ensure data integrity. Additionally, leveraging data analytics and machine learning technologies can enhance the ability to identify and analyze critical assets.

Finally, the strengthening of international cooperation and the creation of a community of experts will contribute to the continuous improvement of the standard. With proper adjustments, ISO/IEC 27037:2012 can remain a reliable guide for digital evidence management, tailored to modern security requirements.

8 Bibliography - sources:

- ISO/IEC (2012) *ISO/IEC 27037:2012 - Information technology — Security techniques — Guidelines for identification, collection, acquisition and preservation of digital evidence*. Geneva: International Organization for Standardization.
- Casey, E. (2011) *Digital Evidence and Computer Crime: Forensic Science, Computers, and the Internet*. 3rd edn. Amsterdam: Elsevier Academic Press.
- Carrier, B. (2005) *File System Forensic Analysis*. Upper Saddle River, NJ: Addison-Wesley.
- Palmer, G. (2001) *A Road Map for Digital Forensic Research*. Report. Utica, NY: Digital Forensic Research Workshop (DFRWS).
- Kent, K., Chevalier, S., Grance, T. and Dang, H. (2006) *Guide to Integrating Forensic Techniques into Incident Response*. NIST Special Publication 800-86. Gaithersburg, MD: National Institute of Standards and Technology (NIST).
- Pollitt, M. (2010) "A history of digital forensics", *Advances in Digital Forensics* 17,4(2), pp. 3-15.
- INTERPOL (2020) *INTERPOL Guidelines for Digital Evidence*. Available at: <https://www.interpol.int> (Accessed: 20 January 2025).
- European Commission (2018) *General Data Protection Regulation (GDPR)*. Available on: <https://eur-lex.europa.eu> (Accessed: February 20, 2025).
- Code of Criminal Procedure, Article 265 (2020) "*Seizure of digital data and evidence*". Athens: Nomiki Bibliothiki.
- Lyle, James R., et al. "Digital Investigation Techniques: A NIST Scientific Foundation Review." May 2022. <https://doi.org/10.6028/NIST.IR.8354-draft>. May 2022.

APPENDIX I - DIGITAL EVIDENCE DICTIONARY

Definitions

- **Binary** – A base-2 representation for numbers that uses a sequence of 1's and 0's to write a number.
- **BIOS** - Basic Input Output System. A number of machine code routines that are stored in ROM and available for execution at boot time.
- **Browser** - Browser is short for Web Browser. A browser is a computer program that locates and displays pages from the Internet.
- **Cache** - A computer's cache is an area where the computer can temporarily store frequently used data that would otherwise have to be loaded from a slower source. The computer's cache speeds up the operation of the computer.
- **CDFS** - The standard used to describe the file structure on a CD.
- **Chip-Off Extraction** – A method of data extraction which involves the removal of a flash memory chip from the printed circuit board (PCB) of a device and directly reading the binary data from the flash memory chip. This type of data extraction is considered destructive as the device will be permanently inoperable after the memory chip is removed from the PCB.
- **Clone** - The process of performing a sector-by-sector copy operation from the suspect drive to the destination drive. The number of sectors copied is determined by the size of the suspect drive.
- **Cluster Bitmaps** - Used by NTFS to track free clusters by using a bitmap. This file contains one bit for every cluster on the volume.
- **Clusters** - A group of sectors in a logical volume that is used to store files and folders.
- **Compressed File** - A file that has been reduced in size via one or more compression techniques.
- **Compression** - A method of storing files resulting in great savings in disk storage space. Compressed blocks are checked for validity in the same way as uncompressed blocks.
- **Control Image** – A forensic image of a known piece of media.
- **Control Media** – A standard piece of media with a known hash value.
- **Cookie** - A cookie is a short piece of data that Web servers place on your computer to help identify Web users. Cookies can be used by Web servers to track your Internet browsing habits.
- **Cylinder** - The set of tracks on the drive platters that are at the same head position.
- **Data Acquisition** – The general process of making a copy of digital data. This can be an entire digital device, just a partition from a storage device, or selected files from a file system.
- **Digital Evidence** – Digital evidence or electronic evidence is any probative information stored or transmitted in digital form that a party to a court case may use at trial.
- **Device Interface Board (DIB)** – An adapter affixed to a circuit board to enable connection between the circuit board and the forensic computer.
- **Disk** – An actual piece of hardware that can be held physically. It could be a floppy disk, hard disk, ZIP disk, etc.
- **Disk Imaging** – The process of acquiring the digital contents of a storage device (fixed disk, removable disk, flash drive, etc.). This acquires all the data on a device including files, metadata, and contents of unallocated areas of the device.
- **DOS** - Disk Operating System - Usually refers to MS-DOS. This operating system, which was developed by Microsoft for IBM compatible PCs, is still used today to help control operation on computers and operates beneath the Windows environment.
- **Drive Geometry** - The number and position of the bytes, sectors, tracks located on the physical drive.
- **Electrostatic Discharge (ESD)** – An uncontrolled and sudden flow of electrons from one object to another caused by contact between the two objects.
- **Encrypt** – To encode information in a way that prevents unauthorized access. For example, decryption with a key is required to access the information.
- **ExFAT** – Extensible File Allocation Table. A revised implementation of the FAT file system introduced in 2006 that addresses some shortcomings in the FAT file system e.g., allows files larger than 4GB, and faster performance.
- **EXT2** - The primary file system used on the Linux operating system.
- **FAT**- File Allocation Table
- **Fdisk** - DOS program that provides information about, and editing of, the partitions on a hard drive.
- **File Entries** - Each folder contains a starting cluster and can be expanded or contracted as files are added or removed from the folder. Each file in the folder is represented by a 32-byte entry in the table. The content of a folder "file" is an array of records containing information about the files in the folder. Each entry in the folder can be either a file or another folder. In this way, a "tree" structure can be built.
- **File Slack** - The space between the logical end and the physical end of a file.
- **File Signature** - A few bytes at the beginning of some files (such as graphic or document files) that constitute a unique signature of the file type, regardless of the file extension used.
- **File System** – A method of organizing files on a storage device. Common file systems on Windows systems are NTFS<lt ExFAT, and FAT>> LINUX systems use ext4 and FAT. Apple Macs use HFS+, APFS, FAT and ExFAT.

- **File allocation table (FAT)** - An array of numbers that sits near the beginning of a DOS volume. The length of the numbers is determined by the size of the volume. Each entry in the FAT corresponds directly to one cluster and there is always one FAT entry for every cluster.
- **Filter Set** – A collection of filters and/or processes designed to clarify a specific audio recording.
- **Finalize** – To format a CD such that no additional data can be added or removed.
- **Forensic Image** – A bit stream copy of available data (i.e. an exact copy), which may result in an encapsulated proprietary format
- **Forensic Tool** – Forensic software tool or standalone hardware device utilized to conduct acquisitions in casework.
- **Format** - DOS command used to prepare a storage medium (hard drive, floppy disk) for reading and writing. Format does not erase data on the disk. It checks for bad sectors and resets the internal address tables (FAT).
- **Hash Value** – An alphanumeric value that uniquely represents a set of data.
- **Hash Value Set (File Filter)** – A list of hash values of known files used within a forensic software tool to show or mask files on a forensic image that have a hash value contained within the list. A file filter does not alter any data on a forensic image
- **Head** - A device that rides very close to the surface of the platter and allows information to be read from, and written to, the platter.
- **HFS Plus** – Hierarchical File System Extended. Apple file system introduced in 1998, replaced by APFS in 2017.
- **Hyperlink** – A hyperlink is a text phrase (which often is a different color than the surrounding text) or a graphic that conceals the address of a website. Clicking on the hyperlink takes you to the website.
- **Image Drive** - Same as the target drive.
- **Initial Hash** – A hash value that has been established before conducting any examination to be used to compare to other hash values.
- **Internet** - The Internet is a worldwide network with more than 100 million computer users that are linked for the exchange of data, news, conversation, and commerce. The Internet is a decentralized network that no one person, organization, or country controls.
- **ISDN Line** - Integrated Services Digital Network - A phone line that connects two computers to transmit a digital signal between them, as opposed to the analog signal transmitted over normal phone lines. This allows data to be transferred more than twice as fast as with an analog phone line with a 56kbps modem.
- **JTAG** – Joint Action Test Group. An industry standard for verifying designs and testing printed circuit boards after manufacture.
- **Logical Drive** - A drive named by a DOS drive specifier, such as C: or D:. A single physical drive can act as several logical drives, each with its own specifier.
- **Logical extraction** – A method of extraction that includes user data available through the device's Application Program Interface but does not include deleted data or unallocated space.
- **Logical File Size** - The exact size of a file in bytes and is the number represented in the properties for a file. This is different than physical file size.
- **MAC Times** – Time stamp metadata maintained by a file system to track events in the life cycle of a file. The exact events recorded depends on the operating system and the file system. The usual meaning are Modify, Access, and Create with slight differences in meaning for each type of file system and differences in meaning for files and directories.
- **Master Boot Record (MBR)** - The very first sector of a physical disk (sector zero). It contains machine code that allows the computer to find the partition table and the operating system.
- **MD5** – Message Digest 5. A 128-bit value that uniquely describes the contents of a file. This is a standard hash code used in forensics.
- **Metadata** – A description of stored data. Categories of metadata include: (1) application metadata, (2) file system metadata, (3) partition metadata that identifies the type of file system the partition contains and global file system parameters, and (4) device metadata describes the layout of partitions on a device.
- **microSD Card** – The microSD (Secure Digital) card found in some devices that may contain user data.
- **M26 Dataport Download Kit** – Kit containing the hardware and software needed to download the firing information from a Serial Connection Taser.
- **Non-Standard Audio Video Result Statements** – Result statements which vary in their content due to the nature of the audio or video being enhanced and/or due to the nature of the case being worked.
- **NTFS** - New Technology File System. The file descriptors for every file on an NTFS volume are stored in the Master File Table.
- **Operating System** – The software that creates the digital environment for running software on a computer or other digital device. Most operating systems use variants of either MS Windows (95, 98, 2000, Vista, XP, 10, etc.) or UNIX (BSD, Linux, Mac OS, iOS, etc.).
- **Partition** – A contiguous area of a storage device used to contain a formatted file system.
- **Partition Table** - Describes the first four partitions, their location on the disk, and which partition is bootable.
- **PGP** - Pretty Good Privacy - Program used to encrypt data on a computer, such as messages on the Internet.
- **Physical Drive** - A single disk drive. A single physical drive may be divided into multiple logical drives.
- **Physical Extraction** – A method of extraction that includes a bit-by-bit image of the flash memory of a device that contains system and user data to include deleted data, hidden data, and unallocated space.
- **Physical File Size** - The amount of space that a file occupies on a disk. A file or folder always occupies a whole number of clusters even if it does not completely fill that space.
- **Plug-ins** - Computer hardware or software that adds a specific feature or service to a larger system.
- **Post Exam Hash** – A hash value that is used to ensure data has not been corrupted/changed by comparing the data's initial hash value to the calculated hash value after completing an exam.
- **Power-On Self Test** – A series of diagnostic tests that are performed when a computer powers on and determines proper functioning of the hardware components.
- **PPE** – Personal Protective Equipment
- **RAM Slack** - The space from the end of the file to the end of the containing sector. Before a sector is written to disk, it is stored in a buffer somewhere in RAM.
- **RAM** - Random Access Memory. Volatile read/write memory whose contents are lost when the power is turned off.

- **Removable Media** – A storage device that is either (1) a data container that is inserted and removed from a data reader or (2) a storage device that can be connected or removed from a computer while the computer is running.
- **ROM** - Read Only Memory. Chips contain a permanent program that is burned on the chip at the factory and maintained when the power is turned off. The information on these chips can be read; however, information cannot be written to the chip.
- **Root Folder** - Stored in a known location, this is a tree structure that supports files and folders within folders to an arbitrary depth.
- **SATA** – Serial ATA. A protocol for connecting storage devices to a host computer.
- **Sector** - A group of bytes within a track and the smallest group of bytes that can be addressed on a drive. The number of bytes in a sector can vary, but is almost always 512.
- **SHA** – Secure Hash Algorithm..
- **SHA-1** - A 160-bit value that uniquely describes the contents of a file. This is a standard hash code used in forensics.
- **SHA-256** - A 256-bit value that uniquely describes the contents of a file. This is a standard hash code used in forensics.
- **SIM Card** – The Subscriber Identity Module card used in some devices that allows the device to connect to a carrier network (AT&T, Verizon, Sprint, etc.). SIM cards may contain identifying information and other data.
- **SIM Card Adapter** – A device used to connect the various types of SIM cards (micro or nano) to the forensic tool for extraction
- **Spam** - Unsolicited “junk” e-mail which is sent to persons who did not request it. It is usually commercial e-mail.
- **Standard Audio Video Result Statements** – Result statements which are common for all audio video cases regardless of the type of case being examined.
- **Storage Device** – An electronic or optical device that can store data for later retrieval. A storage device usually has some type of file system to organize the stored data as files. There are several types including fixed media physically installed in a computer, removable media, memory card, or optical disk.
- **Suspect Drive** - The drive (or drives) that are removed from a subject’s computer, or in the possession of a subject, that will be imaged for later analysis. This drive is never analyzed; rather is copied so the analysis can be conducted on the forensic image.
- **System Drive** - The drive that contains the operating system (OS)
- **System Image** – Backup of the system drive that contains a clean install of the operating system (OS).
- **Target Drive** - A sterile piece of media used to store forensic image(s) and case related data
- **Track** - Each platter on a disk is divided into thin concentric bands called tracks. Tracks are established when the disk is low level formatted.
- **Upload** - To send or transmit data from one computer to another computer or network.
- **URL** - Universal Resource Locator - An address at which documents or other resources can be found on the Web.
- **USB Data Interface Module** – Kit containing the hardware and software need to download the firing information from the USB connection Taser.
- **USB DPM** – Connector from the interface module which plugs into the battery compartment of the USB Taser.
- **Verification Hash** – A hash value that is used to ensure data has not been corrupted/changed by comparing the data’s hash value to a previously calculated value.
- **Video Mixdown** – Duplicate copy of video already created. These are generally created to add additional processing to a previously processed video.
- **VIN** – Vehicle Identification Number
- **Virtual Machine (VM)** – A software emulation of a computer that executes programs like a real machine.
- **Volatile** – data stored on a device that is lost when power is removed from the device, Removing power usually resets all binary digits to zero.
- **Volume** - A mounted partition. There may be only one volume on a floppy or ZIP disk, or there may be several on a hard disk.
- **Wipe** – A procedure for sanitizing a defined area of digital media by overwriting each byte with a known value.
- **World Wide Web** - A group of Internet servers that supports HTML formatting. The World Wide Web is one part of the Internet.
- **Write-Blocker** – A read-only software or hardware device that protects the integrity of the original evidence by not allowing any writes or alterations to occur during the acquisition process.
- **Write Blocking** – Techniques designed to prevent any modification to digital media during acquisition or browsing.
- **Write Protection** – A method by which media content is protected from inadvertent alteration or deletion.

